

Supplementary Material S1

Full HIMS Rubric (Extended 0–5 with Anchor Examples)

Manuscript Title: HIMS-CDI: A Governance Specification and Assurance Architecture for CTI-Driven Cybersecurity Risk Assessment in Healthcare

Authors: Oluseun Akeredolu, Gregory Epiphaniou, Carsten Maple

DOI of main manuscript: [to be assigned]

Repository: <https://github.com/oluseun-akeredolu/HIMS-CDI>

Zenodo archive: <https://zenodo.org/records/16897633>

S1.1 Purpose and Structure

This document provides the complete, expanded version of the Hybrid Integration Maturity Scale (HIMS) rubric introduced in the main manuscript (Table 2). While the main-text table offers a condensed overview suitable for a journal article, the present supplementary material anchors each maturity level (0–5) with concrete, measurable examples and artefact requirements. The rubric is designed to evaluate any CTI-driven cybersecurity risk assessment (CSRA) system across six governance-critical domains: Accuracy, F1 Score, Compliance, Explainability, Edge Readiness, and Latency. All thresholds and definitions are identical to those in the main manuscript; no new scoring logic is introduced.

The extended rubric is intended for use by:

- Clinical safety officers conducting pre-deployment governance assessments,
- Regulatory auditors verifying clause-level traceability,
- System developers aiming to meet specific maturity targets,
- Researchers reproducing or benchmarking against the HIMS-CDI framework.

Scoring convention: Each domain is scored independently from 0 (absent) to 5 (optimised). The scores are not additive across domains; a high score in one domain cannot compensate for a low score in another, in accordance with the non-compensatory constraint architecture. The full HIMS rubric does not itself define pass/fail thresholds—those are set by the governance gates described in the main manuscript (§3.3).

S1.2 Domain-by-Domain Extended Descriptions

The following subsections present each domain with detailed anchor examples for maturity levels 0 through 5. Where applicable, the examples reference specific evaluation protocols, artefact types, and performance boundaries.

S1.2.1 Accuracy

Definition: The proportion of correct predictions (both threat and non-threat) made by the CSRA system on a representative test set, expressed as a percentage. Accuracy is evaluated under the same data conditions and threat distributions as the intended deployment context.

Level	Label	Anchor Examples & Evidentiary Requirements
-------	-------	--

0	Absent	No accuracy metric reported, or reported only on training data without any hold-out set.
1	Minimal	Accuracy < 70 % on a single hold-out test set (no cross-validation). No correction for class imbalance.
2	Emergent	Accuracy 70–79 % on an internal, randomly split test set. Basic train/test separation documented, but no confidence intervals provided.
3	Established	Accuracy 80–89 % with k-fold cross-validation ($k \geq 5$) and reported confidence intervals (e.g., 95 % CI). Validation uses a dataset representative of the target clinical environment (e.g., NHS network traffic).
4	Advanced	Accuracy 90–94 % on a proxy validation dataset (e.g., a publicly available healthcare cybersecurity benchmark such as CIC-IDS-2017 or a curated hospital network dataset). Results are accompanied by per-class precision, recall, and F1 metrics.
5	Optimised	Accuracy ≥ 95 % in an externally conducted evaluation on operational healthcare data (e.g., a multi-site NHS study). All results are fully reproducible, with code, data splits, and random seeds archived.

Special considerations: Accuracy alone is insufficient for imbalanced datasets; therefore, F1 score is evaluated concurrently (see S1.2.2). A model reporting high accuracy but extremely low recall on the threat class would be flagged by the F1 domain and would not achieve the higher HIMS levels.

S1.2.2 F1 Score

Definition: The harmonic mean of precision and recall, computed macro-averaged across all classes (threat and non-threat) unless otherwise specified. Macro-averaging treats all classes equally, penalising models that perform well on majority classes but poorly on minority threat classes.

Level	Label	Anchor Examples & Evidentiary Requirements
0	Absent	F1 score not reported, or only overall accuracy is given.
1	Minimal	Macro F1 < 0.65, and no discussion of class imbalance or mitigation strategy.
2	Emergent	Macro F1 0.65–0.74, with a documented mitigation approach for class imbalance (e.g., SMOTE, class weighting, oversampling).
3	Established	Macro F1 0.75–0.84, validated using stratified k-fold cross-validation ($k \geq 5$) with per-fold and overall confidence intervals.
4	Advanced	Macro F1 0.85–0.89 on multiple healthcare-specific CSRA tasks (e.g., separate evaluations for ransomware detection, phishing, and lateral movement).
5	Optimised	Macro F1 ≥ 0.90 in an external, independent validation study using real-world healthcare CTI feeds and ground-truth labels verified by SOC analysts.

Note on relationship with AUROC: The main manuscript discusses the relationship between AUROC and Macro-F1 in the context of the specification-recoverability evaluation (see §6.1). For general CSRA system assessment, both metrics should be reported, but the HIMS rubric focuses on F1 because of its direct sensitivity to class-wise performance.

S1.2.3 Compliance (Regulatory Traceability)

Definition: The degree to which the CSRA system’s decision-making can be mapped to specific regulatory clauses and verified through machine-readable evidence artefacts. This domain does not assess legal sufficiency, only traceability. The clause set consists of 27 requirements drawn from GDPR Art. 32, HIPAA § 164.308, and NHS DSPT v8.3.

Level	Label	Anchor Examples & Evidentiary Requirements
0	Absent	No mention of data-protection regulations, or only a generic statement with no mapping.
1	Minimal	Nominal mention of GDPR, HIPAA, or DSPT (e.g., “the system complies with GDPR”), but no clause-by-clause mapping.
2	Emergent	Partial mapping: at least 50 % of applicable regulatory clauses are linked to high-level system design descriptions, but no verifiable evidence artefacts are provided.
3	Established	Full clause-level mapping with a documented checklist. The mapping is traceable to specific system components (e.g., “encryption module satisfies GDPR Art. 32(1)(a)”), but evidence logs are not automated.
4	Advanced	Automated clause-level mapping with machine-readable logs (JSON format). Partial evidence artefacts (e.g., configuration files, static policy documents) are linked. Runtime verification is not yet implemented.
5	Optimised	Full runtime audit logging: every regulatory clause is continuously verified, and all evidence artefacts are cryptographically hashed and timestamped. A complete Evidence Traceability Package (ETP) is generated automatically and can be inspected by auditors without system-side cooperation.

Clause set version: The complete 27-clause enumeration with evidence-artefact mappings is provided in S5_clause_list.json (within Supplementary Material S5). The present rubric only references the traceability level.

S1.2.4 Explainability

Definition: The extent to which clinical and security stakeholders can understand the CSRA system’s outputs. The domain is a composite of interpretability (structural transparency) and usability (human-factors evaluation), with weights approximately 0.6/0.4; the derivation is documented in Supplementary S6 (AHP Matrices & Delphi Protocol). In the rubric, overall maturity is assigned based on the composite score.

Level	Label	Anchor Examples & Evidentiary Requirements
-------	-------	--

0	Absent	Model predictions are completely opaque; no explanation mechanism is provided.
1	Minimal	Post-hoc explanations only, using a generic library (e.g., SHAP or LIME applied without domain adaptation). No usability testing.
2	Emergent	Rule-based local explanations (e.g., “Alert triggered because IP is on a known blacklist”) are generated for each alert. No global model-level explanation. Usability has not been formally assessed.
3	Established	Both local and global explanations are available. Local explanations provide feature attributions; global explanations describe the model’s overall decision logic (e.g., decision-tree surrogate). A usability study with ≥ 50 participants (clinicians or SOC analysts) achieves a System Usability Scale (SUS) score ≥ 50 .
4	Advanced	Explanations are integrated into a clinical dashboard or SOC interface. The system meets GDPR Art. 22 requirements for human-in-the-loop oversight. Usability testing with $\geq 70\%$ SUS score.
5	Optimised	Fully GDPR-aligned explainability pipeline with human-in-the-loop confirmation for all high-risk decisions. Usability testing with $\geq 85\%$ SUS score. All explanations are archived alongside audit logs for post-hoc review.

Measurement note: The explainability composite is computed using the formula and sub-metric definitions in Supplementary Material S6 (AHP Matrices & Delphi Protocol). The rubric level is derived from the composite score, not from a single sub-metric.

S1.2.5 Edge Readiness

Definition: The ability of the CSRA system to execute on resource-constrained clinical edge hardware, typically a Raspberry Pi 4 (4 GB RAM) or equivalent, under concurrent request loads representative of a busy ward environment (5 concurrent inference requests).

Level	Label	Anchor Examples & Evidentiary Requirements
0	Absent	Edge-deployment feasibility has not been assessed.
1	Minimal	Only a conceptual argument is provided (e.g., “the model is lightweight”), without any measurements.
2	Emergent	Either inference latency or peak memory usage has been measured on edge hardware, but not both. The measurement is performed under a single request only.
3	Established	Both latency and memory have been measured on representative edge hardware (Raspberry Pi 4 or equivalent). One of the two targets (latency < 200 ms, memory < 100 MB) is met. Concurrency is tested with at least 5 simultaneous requests.

4	Advanced	Both latency and memory targets are met under concurrency. Measurements include 95th-percentile latency (not just mean) to capture tail behaviour.
5	Optimised	The system is stable under sustained concurrency for ≥ 1 hour without memory leaks or degradation. Resource usage logs are automatically recorded and cryptographically signed for audit.

Hardware specification: All measurements shall be conducted on a Raspberry Pi 4 Model B with 4 GB RAM, running Raspberry Pi OS Lite (64-bit), with only the necessary inference services active. Full benchmark scripts and results are available in Supplementary Material S14–S15.

S1.2.6 Latency

Definition: End-to-end inference latency, measured from the moment a pre-processed threat indicator is presented to the model until the risk score is returned, on the target clinical edge device. Latency excludes network transmission time from a remote sensor to the edge node but includes all on-device preprocessing and postprocessing.

Level	Label	Anchor Examples & Evidentiary Requirements
0	Absent	Latency has not been measured or reported.
1	Minimal	Mean latency > 500 ms on any hardware; no attempt made to profile or optimise.
2	Emergent	Mean latency 300–500 ms on the target edge hardware. Measurements are taken under a single, no-load condition.
3	Established	Mean latency 200–300 ms on the target edge hardware, with measurements repeated across multiple runs to confirm reproducibility.
4	Advanced	Mean latency 100–200 ms on the target edge hardware, with 95th-percentile also reported and all measurements fully reproducible (scripts and seeds provided).
5	Optimised	Mean latency < 100 ms, with worst-case (99th-percentile) latency bounded below 200 ms under concurrency. All measurements are automated and continuously monitored in a CI/CD pipeline.

Important: The latency score is an independent domain; even if Edge Readiness is scored highly, a poor latency score can independently block deployment via the governance gates (latency < 200 ms).

S1.3 Inter-Rater Reliability of the Rubric

The HIMS rubric was piloted with two independent raters (a clinical safety officer and a healthcare cybersecurity architect) who assessed 50 synthetic CTI-CSRA profiles using only the condensed rubric (main text Table 2) and the present extended anchor examples. The inter-rater agreement was Cohen's $\kappa = 0.84$ (95 % CI: 0.79–0.89), exceeding the prespecified acceptance threshold of $\kappa \geq 0.80$. This reliability estimate was obtained *before* the Delphi/AHP weight elicitation and thus reflects the clarity of the rubric descriptors rather than expert calibration drift.

S1.4 Relationship to Main-Text Table 2

The main manuscript’s Table 2 is a condensed version of the present document, optimised for journal page limits. The two are semantically identical; no threshold or domain definition has been changed. In the event of any perceived ambiguity, the present S1 extended descriptions shall take precedence as the authoritative specification.

S1.5 Machine-Readable Version

A machine-readable JSON Schema of the full rubric, suitable for integration into automated evaluation pipelines, is available in the repository under `/rubric/hims_rubric_schema.json`. The schema encodes all domain definitions, score thresholds, and anchor examples in a structured, version-controlled format. The schema version in the repository corresponds to the version used in the synthetic evaluation reported in the main manuscript.

Document version: 1.0

Last updated: 10 May 2026